



OWASP PTK Security Report

Website Vulnerability Scanner Report

localhost

Summary

Risk ratings:

Critical: 0
High: 0
Medium: 0
Low: 1
Info: 0

Engine	Critical	High	Medium	Low	Info	Total
DAST	0	0	0	1	0	1
Total	0	0	0	1	0	1

No confirmed high-risk issues; review potential findings and hardening opportunities.

Exposure & Hygiene:

Headers: No header issues detected or data unavailable.
Token/storage: Tokens in storage: No; Cookie HttpOnly missing: No
Dependencies: No high-risk dependencies identified or data unavailable.

Remediation Plan:

Bucket	Items
Fix now (0–7 days)	0
Fix soon (7–30 days)	0
Backlog	1

General Information

DAST

DAST-0001 - Missing Content-Security-Policy header

http://localhost/student-wallet/student-wallet/frontend/profile.html

LOW Confidence: 78

Request:

```
GET http://localhost/student-wallet/student-wallet/frontend/profile.html HTTP/1.1
Sec-Ch-Ua: "Chromium";v="148", "Google Chrome";v="148", "Not/A)Brand";v="99"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: Windows
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
```

Request:

Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: http://localhost/student-wallet/student-wallet/frontend/dashboard.html
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: en-GB,en-US;q=0.9,en;q=0.8,si;q=0.7
Cookie: ...

Response:

HTTP/1.1 200 OK
accept-ranges: bytes
connection: Keep-Alive
content-length: 4721
content-type: text/html
date: Mon, 25 May 2026 11:00:55 GMT
etag: "1271-650139f32686f"
keep-alive: timeout=5, max=100
last-modified: Wed, 22 Apr 2026 21:57:45 GMT
server: Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.2.12

```
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Profile - Student Wallet</title>
  <script src="https://cdn.tailwindcss.com"></script>
  <link rel="stylesheet"
href="https://cdnjs.cloudflare.com/ajax/libs/font-awesome/6.4.0/css/all.min.css">
</head>
<body class="bg-gray-100">
  <nav class="gradient-bg text-white shadow-lg">
    <div class="container mx-auto px-6 py-3">...
```

Description:

The OWASP Secure Headers Project describes HTTP response headers that your application can use to increase the security of your application. Once set, these HTTP response headers can restrict modern browsers from running into easily preventable vulnerabilities.

Recommendation:

Configure security-related HTTP response headers consistently on all responses to harden the application against common browser-based attacks.

HSTS – enforce HTTPS with a long max-age and includeSubDomains where appropriate. Content-Security-Policy – restrict scripts, styles, frames and connections to trusted sources only. Referrer-Policy – limit referrer information sent to other origins. X-Content-Type-Options – use nosniff to prevent MIME type confusion. Cookies – set Secure, HttpOnly and SameSite attributes on sensitive cookies. Remove unnecessary disclosure headers such as Server and X-Powered-By where possible.

CWE:

CWE-693

OWASP:

A02:2025 - Security Misconfiguration, A05:2021 - Security Misconfiguration

References:

https://owasp.org/Top10/2025/A02_2025-Security_Misconfiguration/
<https://cwe.mitre.org/data/definitions/693.html>

Report generated using OWASP PTK scanning engines. Results depend on scan coverage and target responsiveness.

Scope: N/A

Limitations: Results depend on available routes and auth context; some flows may not be covered.